Практическое задание

Тема: «Анализ вредоносной программы и выбор методов защиты»

Вариант В: рансомер, шифрующий файлы на сервере

Шаг 1. Описание вредоносной программы

Рансомер (ransomware) – это вредоносная программа, которая шифрует данные на заражённой системе и требует выкуп за их расшифровку. Характеристика программы приведена в таблице 1.

Таблица 1 – Характеристика рансомера

Признак	**Описание**
Тип по механизму распространения	Троян. Программа сама не размножается: она попадает на сервер, когда злоумышленник или пользователь запускает её, а затем маскируется под обычный процесс.
Тип по функциональности	Шифровальщик (вымогатель). Блокирует доступ к данным. Может также содержать элементы шпионажа для кражи данных.
Тип по способу монетизации	Рансомер (крипто-рансомер). Выгода – выкуп за расшифровку, а при краже данных – ещё и за их нераспространение (доксинг).
Полезная нагрузка	Шифрование файлов и баз данных на сервере, удаление резервных и теневых копий, создание файла с требованием выкупа.
Способы распространения	Фишинговые письма с вложениями; подбор или кража паролей к удалённому доступу (RDP); использование неисправленных уязвимостей в ПО сервера; скачивание заражённых программ.

Типичный порядок работы такой программы: проникновение в систему, закрепление, повышение прав, поиск ценных файлов, удаление резервных копий, шифрование и вывод сообщения с требованием выкупа.

Шаг 2. Оценка рисков

Результаты оценки рисков сведены в таблицу 2.

Таблица 2 – Оценка рисков

Показатель	**Оценка**
Объекты уязвимости	Операционная система и серверное ПО без актуальных обновлений; учётные записи и службы удалённого доступа; файлы и базы данных; резервные копии; сотрудники (из-за фишинга).
Реализуемые угрозы надёжности	Потеря доступности данных и сервисов; нарушение целостности данных; простой информационной системы; утечка конфиденциальной информации (при краже данных).
Вероятность заражения	Высокая, если не установлены обновления, открыт RDP и слабые пароли. При хорошей защите – средняя.
Тяжесть последствий	Высокая (критическая): остановка работы организации, потеря данных, финансовые и репутационные потери.

Шаг 3. Выбор методов обнаружения

Эффективность каждого метода против рансомера показана в таблице 3.

Таблица 3 – Эффективность методов обнаружения

Метод	**Эффективность**	**Обоснование**
Сигнатурный	Средняя	Быстро и точно находит известные семейства рансомеров, но не обнаруживает новые (zero-day) и изменённые версии.
Эвристический	Выше средней	Может найти неизвестный образец по подозрительным признакам (функции шифрования, обращение к системным файлам). Возможны ложные срабатывания на архиваторах и программах резервного копирования.
Поведенческий	Высокая	Хорошо выявляет характерные действия: массовое изменение и переименование файлов, удаление теневых копий, резкий рост нагрузки на диск. Работает и против новых образцов.

Вывод: лучше всего против рансомера работает поведенческий метод, но на практике его нужно сочетать с сигнатурным, чтобы быстро блокировать уже известные угрозы.

Шаг 4. Меры защиты

Профилактические меры

- регулярная установка обновлений безопасности ОС и серверного ПО;
- использование антивируса с поведенческим анализом;
- ограничение прав пользователей и администраторов;
- использование сложных паролей и двухфакторной аутентификации;
- обучение сотрудников распознаванию фишинга.

Технические меры

- межсетевой экран, закрытие ненужных портов, запрет прямого доступа к RDP из интернета;
- система обнаружения вторжений (IDS) для контроля сетевой активности;
- шифрование конфиденциальных данных;
- резервное копирование по правилу 3-2-1: три копии, на двух разных носителях, одна из них хранится отдельно (офлайн);
- сегментация сети, чтобы заражение не распространялось на другие серверы.

Организационные меры

- политика информационной безопасности;
- план реагирования на инциденты (кто и что делает при заражении);
- регулярный аудит безопасности и проверка восстановления из резервных копий;
- взаимодействие с центрами реагирования на компьютерные инциденты (CERT).

Шаг 5. Наиболее эффективная мера защиты

Наиболее эффективной мерой является регулярное резервное копирование с хранением копий отдельно от основной сети (офлайн). Причина в том, что ни один метод обнаружения не даёт полной гарантии: новый рансомер может пройти мимо антивируса. Если же есть чистая резервная копия, организация может восстановить данные и продолжить работу без выплаты выкупа. Это снижает главный ущерб от атаки – потерю данных и простой.

Резервное копирование нужно дополнять другими мерами: обновлением ПО, ограничением доступа и поведенческим обнаружением, так как они уменьшают вероятность самого заражения.